Attack Simulation Report — FTP Brute Force

1. Attack Overview

This report documents a simulated **FTP brute-force attack** against the Metasploitable2 target in the Wazuh homelab.

Field	Detail
Attack type	FTP brute force (credential guessing)
Tool	Hydra v9.7
Attacker	Kali Linux (10.0.2.15)
Target	Metasploitable2 vsftpd service (10.0.2.3, port 21)
Wordlist	/usr/share/wordlists/rockyou.txt
MITRE ATT&CK	T1110.001 (Password Guessing)
Detection rule	Wazuh custom rule 100017 (added during this exercise)

Objective: demonstrate the attack end-to-end, confirm what Wazuh captures at each stage (raw logs vs. classified alerts), and close a detection gap discovered along the way.

2. Pre-Attack Baseline

Before launching the attack, the Threat Hunting → Events view was queried with `rule.level >= 10` over the last 15 minutes to establish a clean baseline. No FTP-related alerts were present — only unrelated existing alerts (a prior sudo privilege-escalation event and a Windows application error event).

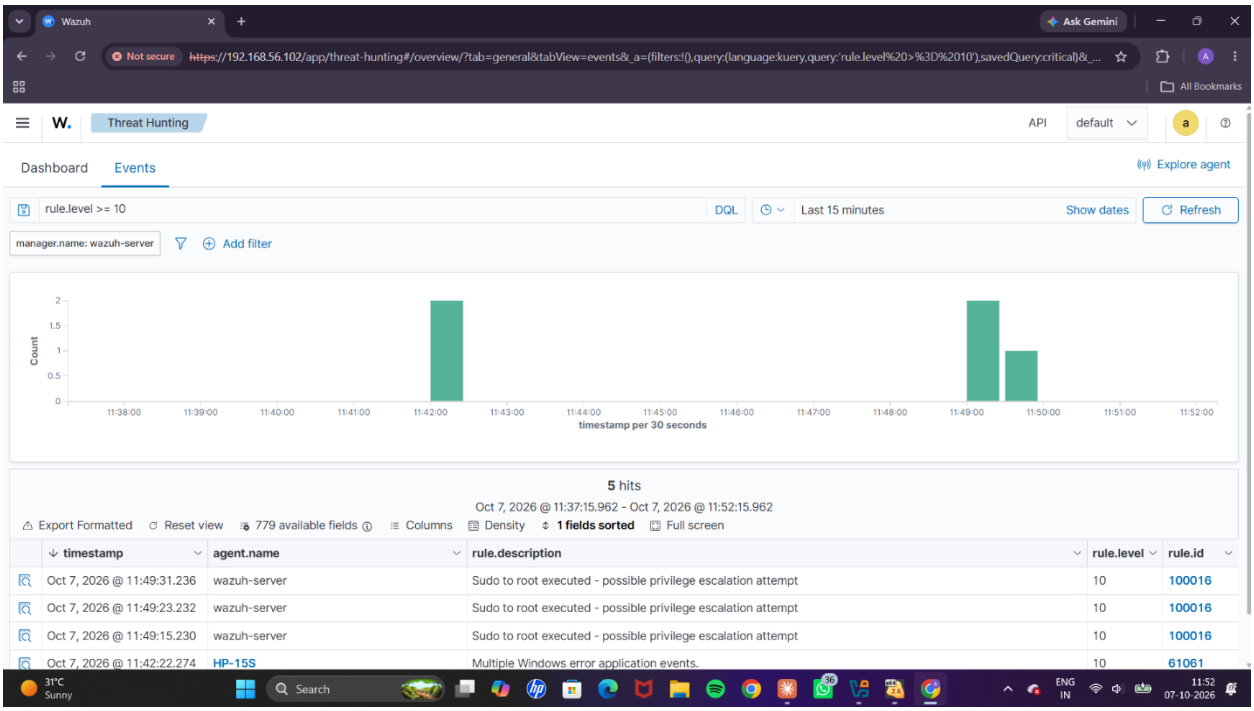


Figure 1: Wazuh Threat Hunting → Events, filtered to rule.level >= 10, before the attack. No FTP activity visible.

3. Attack Execution

Hydra was run from Kali against the Metasploitable2 FTP service, targeting the `msfadmin` account with the rockyou.txt wordlist and 4 parallel tasks:

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ftp://10.0.2.3 -t 4 -V
```

The attack was run twice over the course of this exercise:

1. **Run 1** — against the real `msfadmin` account, to observe a realistic credential-guessing attempt.
2. **Run 2** — against a non-existent `msftest` account, to deliberately sustain failed attempts and validate detection logic (Section 6).

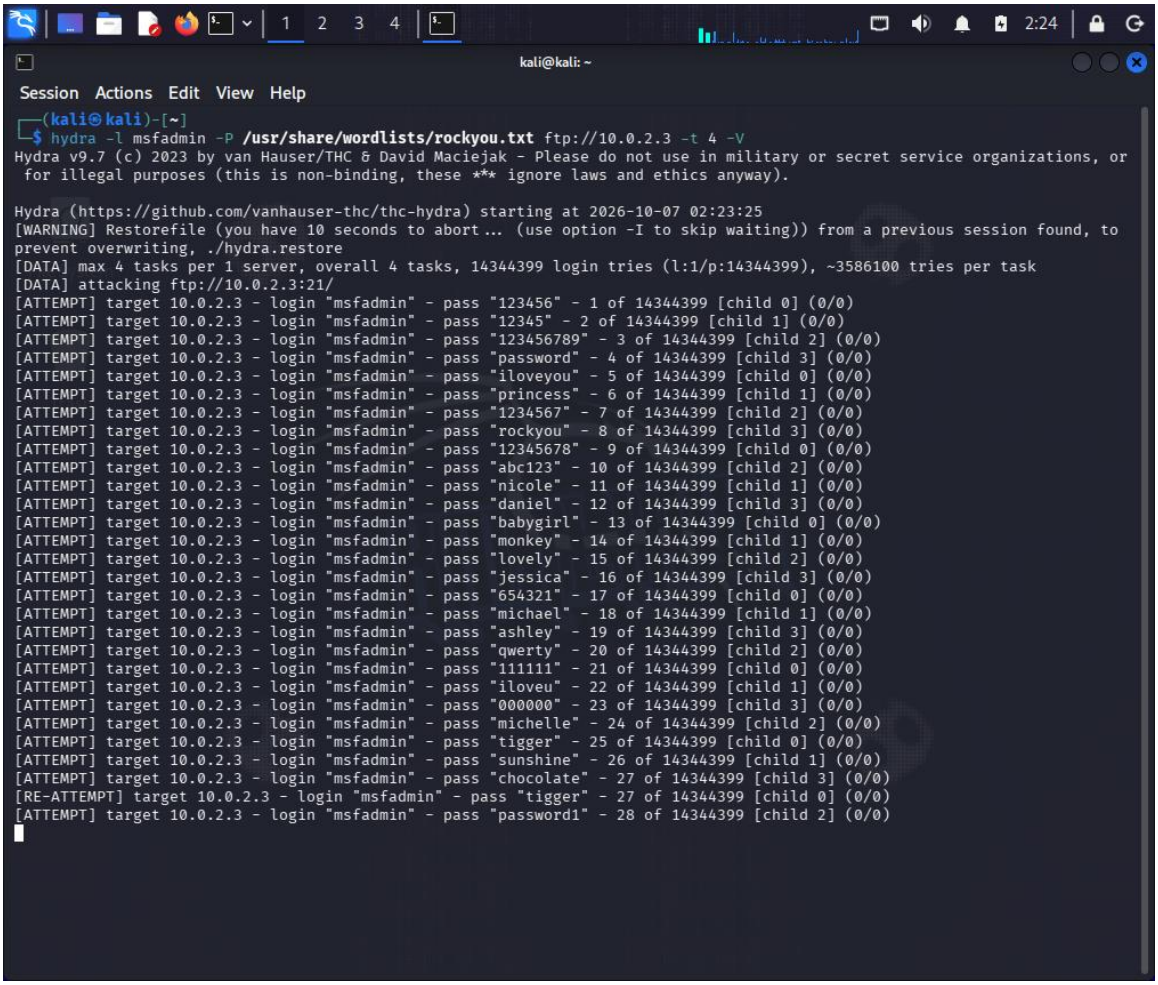


Figure 2: Hydra in progress, `-V` verbose mode showing each password attempt against msfadmin.

4. Raw Log Verification & Initial Detection Gap

Searching Discover for `msfadmin` over the attack window returned 2 hits: a `PAM: User login failed.` event (vsftpd, rule 5503, level 5) followed shortly after by a `PAM: Login session opened.` event (level 3) — confirming Hydra found a **valid credential** (msfadmin:msfadmin) during the run.

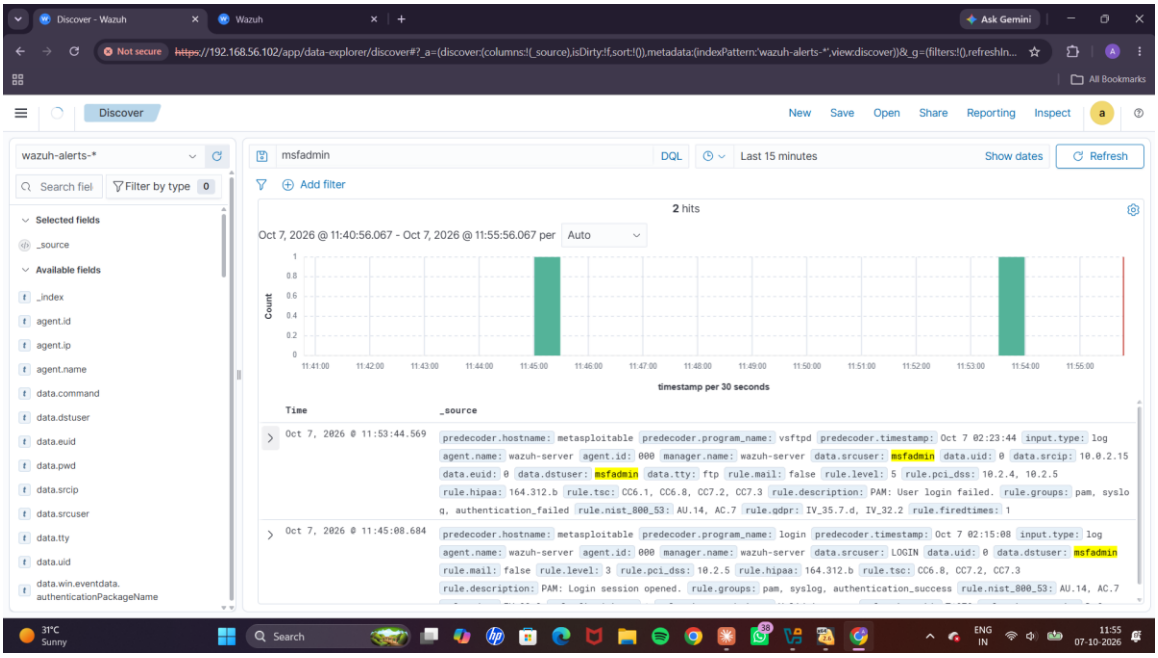


Figure 3: Discover view, query `msfadmin`, showing the PAM failure followed by the successful session.

Finding — detection gap: Re-checking `rule.level >= 10` immediately after the run showed no FTP-related alert. Only 3 pre-existing, unrelated sudo privilege-escalation hits appeared.

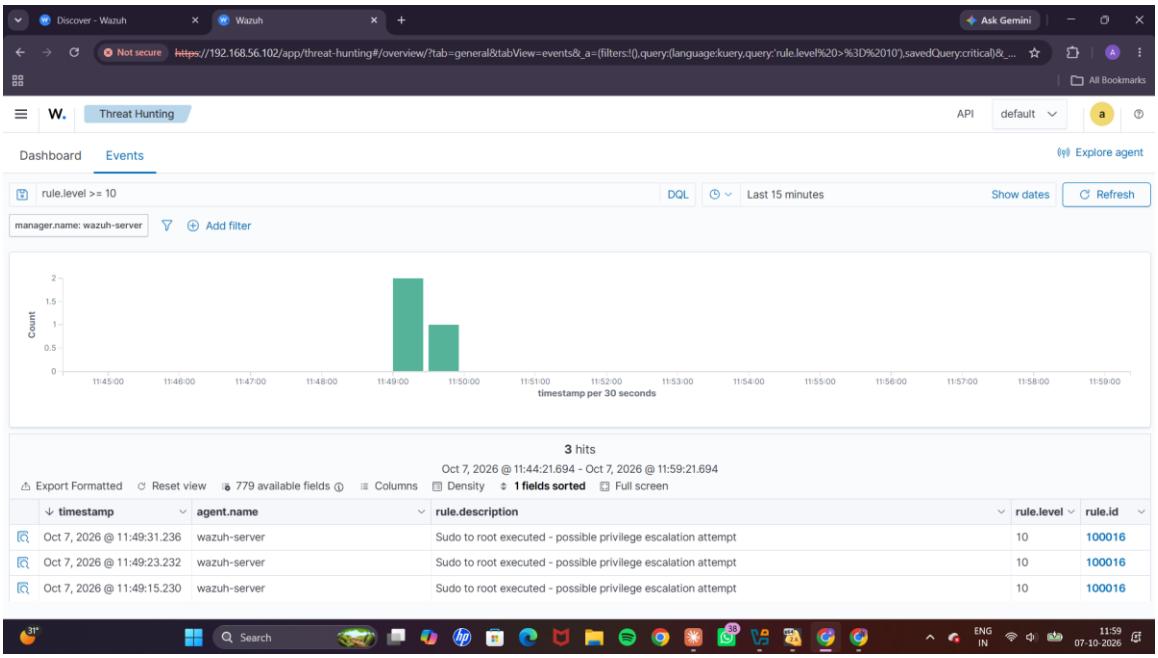


Figure 4: Threat Hunting → Events, rule.level >= 10, post-attack — the FTP brute force produced no high-severity alert.

Root cause: at the time of this run, Wazuh's ruleset had no custom detection rule built on top of the base vsftpd/PAM failure event (rule 5503). Rules 100010–100016 covered SSH brute force, SSH compromise, and sudo privilege escalation, but not FTP. The attack also succeeded in only 2 log lines,

too few to trip a frequency-based rule even if one had existed — Hydra matched the valid password early in the wordlist and stopped.

5. Remediation — Custom Rule 100017

The base rule matched by the vsftpd failure (5503, "PAM: User login failed.", level 5, MITRE T1110.001) was confirmed via the dashboard's Ruleset Test tool against a sample log line:

```
Oct 7 02:23:44 metasploitable vsftpd: pam_unix(ftp:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=msfadmin rhost=10.0.2.15 user=msfadmin
```

A new rule was added to `/var/ossec/etc/rules/local_rules.xml`, built on rule 5503 the same way existing rule 100013 is built on the SSH failure rule (5760) — frequency + timeframe + same-source-IP:

```
<rule id="100017" level="10" frequency="5" timeframe="120">
  <if_matched_sid>5503</if_matched_sid>
  <program_name>vsftpd</program_name>
  <same_source_ip />
  <description>FTP brute force: 5 failed logins in 2 minutes</description>
</rule>
```

The `program_name` constraint scopes the rule to vsftpd specifically, so it will not fire on unrelated PAM failures from SSH or sudo. The ruleset reloaded without error and the rule set now spans 100010–100017.

6. Validation & Alert Confirmation

To validate the new rule deterministically, Hydra was re-run against a **non-existent** account (`msftest`) — guaranteeing every attempt fails and the frequency threshold is crossed quickly, independent of wordlist position:

```
hydra -l msftest -P /usr/share/wordlists/rockyou.txt ftp://10.0.2.3 -t 4 -V
```

Discover showed 55 raw PAM failure events for `msftest` within the attack window (rule 5503, `firedtimes` climbing well past the frequency=5 threshold):

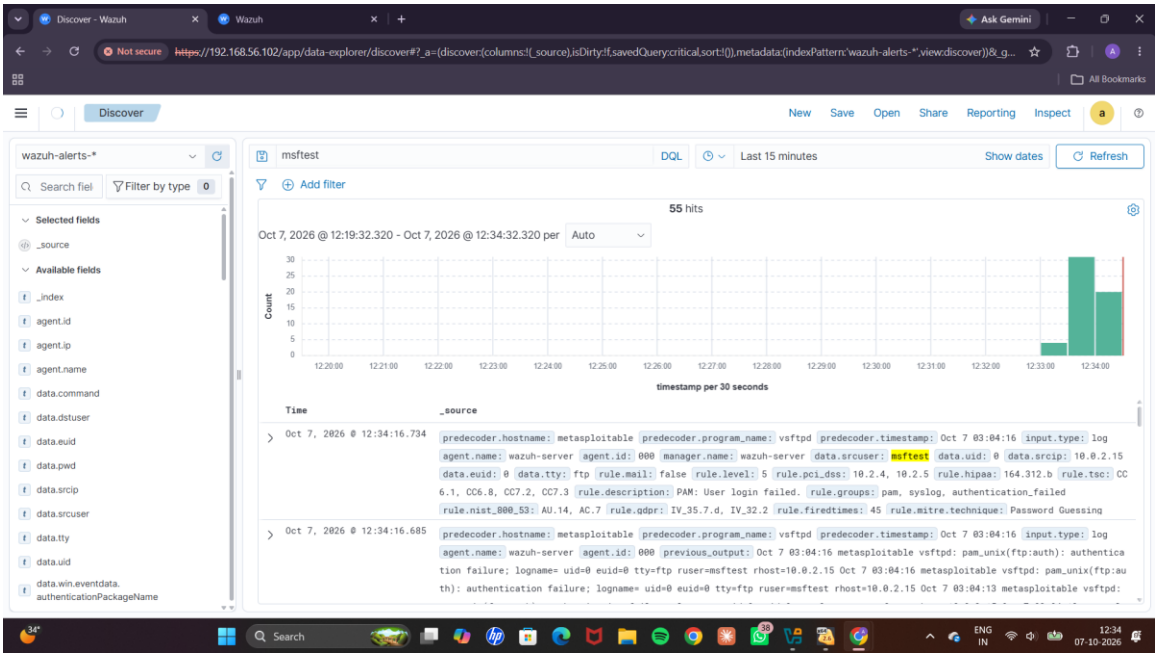


Figure 5: Discover view, query `msftest`, 55 hits — sustained failed FTP logins.

Checking `rule.level >= 10` confirmed rule 100017 firing repeatedly:

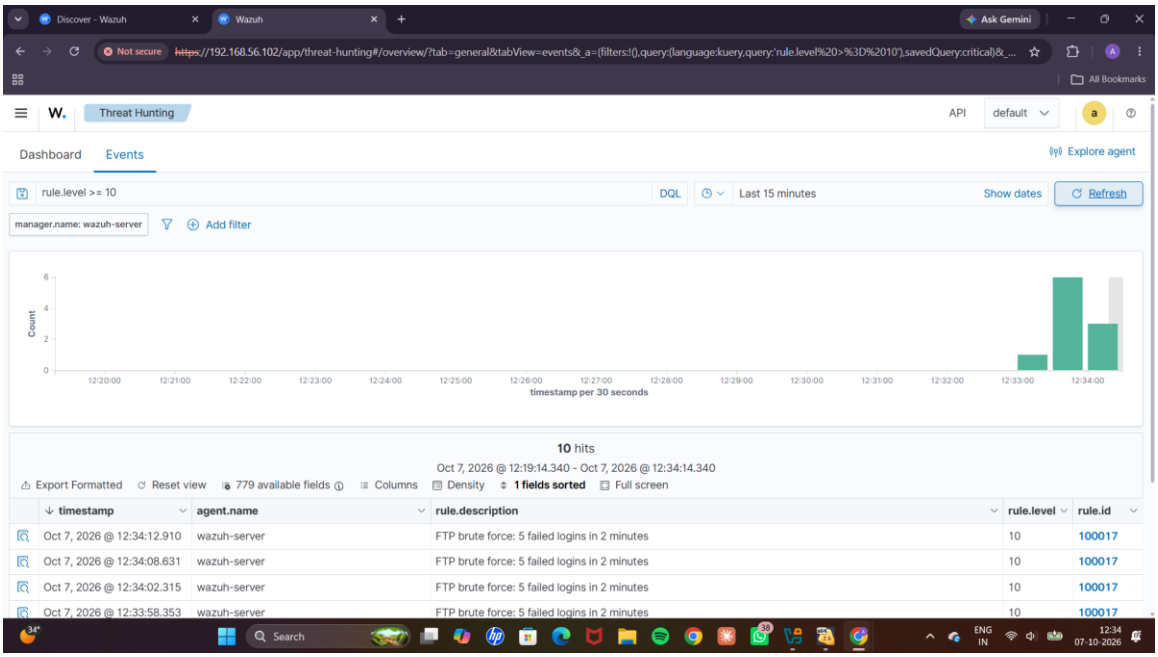


Figure 6: Threat Hunting → Events, rule.level >= 10 — rule 100017 "FTP brute force: 5 failed logins in 2 minutes" now classified and surfaced.

7. Findings & Conclusion

Scenario	Result

Scenario	Result
FTP brute force vs. valid account (msfadmin)	Credential compromised (msfadmin:msfadmin); too few failures to trigger an alert at the time — detection gap
FTP brute force vs. non-existent account (msftest)	55 sustained failures; rule 100017 fired correctly after remediation

This exercise surfaced a real gap in the ruleset — FTP brute force had no dedicated detection logic despite SSH and sudo being covered — and closed it with rule 100017, modeled directly on the existing SSH brute-force rule (100013). The two-run approach also illustrates a realistic failure mode: a fast, successful credential guess can evade a purely frequency-based detection rule, since the attack ends before the threshold is reached. This is worth carrying into future rule design (e.g. also alerting on *any* successful login following *any* prior failure from the same source, mirroring rule 100014 for SSH).